

PENTEL LAB

System Requirements Specification

CanaryNorth Field Console redesign and private synthetic red-team lab

Document ID	PTL-SRS-001
Version	1.0
Status	Implementation baseline
Date	August 16, 2026
Audience	Product, design, engineering, security, QA, and interview reviewers
Classification	Private lab documentation; contains no secrets or operational payloads

Truth boundary: This specification defines a premium interface for a synthetic, redacted, non-executing rehearsal system. It does not authorize real intrusion, malware, credential use, external targeting, or unsupported detector claims.

Document control

Version	Date	Owner	Change
1.0	2026-08-16	Quinn / Rishva Iyer	Initial implementation baseline for the redesigned lab and documentation surface.

Table of contents

- 1. Executive summary
- 2. Product context and scope
- 3. Stakeholders and user classes
- 4. System architecture
- 5. Functional requirements
- 6. Data and state model
- 7. External interfaces
- 8. Security and privacy requirements
- 9. Nonfunctional requirements
- 10. Accessibility and responsive requirements
- 11. Observability and evidence
- 12. Test and acceptance strategy
- 13. Deployment and operations
- 14. Traceability matrix
- 15. Risks, limitations, and release gates
- Appendix A. Status vocabulary
- Appendix B. Current scenario inventory
- Appendix C. Requirement glossary

1. Executive summary

PenTel Lab is a private, access-gated, synthetic red-team rehearsal environment paired with CanaryNorth defensive controls. The current lab presents 72 named scenarios across 64 families, a scored ten-case fixture set, a seven-stage Benji walkthrough, an in-memory OS boundary simulator, a multi-case playbook composer, a coverage map, and redacted action receipts. The target redesign turns those capabilities into a coherent product called the CanaryNorth Field Console.

Primary outcome: A first-time user can understand one threat path, compare unprotected and protected outcomes, inspect the evidence, and accurately explain the safety boundary in under five minutes.

1.1 Success measures

- One guided rehearsal can be completed without external instruction.
- Every visible control navigates, changes state, opens an explanation, or performs a safe local action.
- A user can distinguish blocked, enforced, shadow-only, heuristic-review, not-run, and allowed states.
- A security reviewer can trace input, provenance, requested capability, policy decision, and evidence receipt.
- The interface works at 390, 768, 1280, and 1536 pixel widths with no page-level overflow.
- No redesign work weakens owner access, repository isolation, or synthetic rehearsal boundaries.

2. Product context and scope

2.1 In scope

- Owner-gated browser application served from the approved lab-ui asset root.
- Shared application shell and five primary destinations.
- Threat Constellation visualization and accessible linear fallback.
- Scenario discovery, filtering, explanation, safe rehearsal, comparison, and receipts.
- Multi-threat playbook composition with inert output.
- OS boundary simulator, offline traffic replay, containment controls, privacy inspector, and redacted ledger.
- Coverage Atlas, guided tour, searchable documentation, PDF and DOCX downloads, accessibility, and mobile behavior.
- Regression tests and browser QA for interaction and security boundaries.

2.2 Explicitly out of scope

- Operational exploits, malware, credential collection, account access, external target calls, stealth, persistence, IP spoofing, or anonymity services.
- Live packet sniffing, OS process creation, file-system mutation, socket access, shell commands, browser automation, or device control.
- Claims of malware detection without a real scanner and tested corpus.
- Claims of steganography detection beyond bounded heuristic container review.
- Claims that shadow scoring is trained machine learning or can enforce production policy.
- Public portfolio linking, public attack tooling, multi-tenant production use, or enterprise certification in this release.

2.3 Current baseline and target state

Area	Current baseline	Target state
Presentation	Five bright terminal and toy-hardware pages.	One premium field-instrument design system with shared shell.
Threat navigation	List, filters, detail pane, and coverage table.	Threat Constellation plus accessible list and relationship inspection.
Rehearsal	Safe local replay and action receipt.	Causal animation, protected comparison, evidence timeline, and receipt.
Playbooks	Up to four selected cases with inert code output.	Ordered visual composer, compatibility feedback, plain English, pseudocode, and evidence plan.
Documentation	Markdown dashboard guide.	Authenticated Guide + SRS page with branded downloads.
Security	Fragment gate to HttpOnly cookie; approved assets only.	Preserved without exposing the secret to client-readable storage.

3. Stakeholders and user classes

User class	Primary need	Experience requirement
Owner / builder	Operate, explain, and extend the lab safely.	Fast navigation, deep detail, exports, clear current-vs-planned status.

User class	Primary need	Experience requirement
Beginner learner	Understand threats without security jargon.	One-sentence explanations, guided mode, glossary, visible boundaries.
Security engineer	Inspect trust boundaries, controls, and evidence.	Technical mode, exact state, provenance, requirement and test references.
Hiring manager or judge	Assess product judgment and technical credibility.	Five-minute guided narrative, honest claims, polished presentation.
Keyboard or assistive-tech user	Access every operation without visual-only cues.	Semantic controls, focus, live status, graph alternative, reduced motion.

4. System architecture

The release uses a deliberately narrow presentation architecture. The Node server provides the owner gate and serves approved static assets. Browser modules operate on synthetic fixture data and local in-memory state. The private runner, fixtures, tests, repository documents, and defensive development checkouts remain outside the served asset root.

Layer	Responsibility	Trust boundary
Owner gate	Accept fragment-carried token, exchange over HTTPS, issue secure session cookie.	Unauthenticated to authenticated browser session.
Static server	Serve approved lab-ui assets with no-store, noindex, CSP, and anti-framing headers.	Repository to presentation asset allowlist.
Shared shell	Navigation, command palette, run strip, documentation, and responsive layout.	Page-to-page application state.
Scenario model	Provide redacted names, families, surfaces, boundaries, status, and safe fixtures.	Untrusted story to typed safe metadata.
Rehearsal engine	Advance authored local state and emit redacted evidence events.	Requested action to local decision model.
Evidence layer	Show human explanation, receipt, ledger, and downloadable safe artifacts.	Internal state to human-readable proof.

5. Functional requirements

5.1 Authentication and session

ID	Priority	Requirement	Verification
AUTH-001	Must	The system shall require a server-configured owner token of at least 32 characters.	Automated server test rejects missing and short tokens.
AUTH-002	Must	The owner link shall carry the access secret in the URL fragment, not the request query or path.	Browser and request-log inspection.
AUTH-003	Must	The gate shall remove the secret fragment before opening an authenticated	Browser URL assertion after access.

ID	Priority	Requirement	Verification
		page.	
AUTH-004	Must	The server shall exchange the owner token for an HttpOnly, Secure, SameSite=Strict cookie.	Response-header test.
AUTH-005	Must	Unauthenticated requests for lab pages and downloadable documents shall return 401.	Route smoke test.
AUTH-006	Must	Repository files outside the approved asset root shall return 404 even after authentication.	Negative route test for README and package files.
AUTH-007	Must	The owner session shall expire after a bounded period and support safe token rotation.	Cookie max-age assertion and rotation runbook.

5.2 Shared shell and navigation

ID	Priority	Requirement	Verification
NAV-001	Must	The system shall expose Control Room, Threat Workbench, OS Boundary Lab, Coverage Atlas, Guided Tour, and Guide + SRS destinations.	Navigation test on every page.
NAV-002	Must	The current destination shall expose aria-current and a visible state.	DOM assertion and keyboard QA.
NAV-003	Must	The command palette shall search pages, scenarios, and definitions.	Search result integration test.
NAV-004	Must	Mobile navigation shall use labeled touch targets of at least 44 pixels.	390-pixel browser measurement.
NAV-005	Must	The persistent run strip shall show scenario, run ID, mode, step, decision, and reset.	Component state test.

5.3 Control Room

ID	Priority	Requirement	Verification
CRM-001	Must	The Control Room shall explain the product outcome in one headline and one supporting sentence.	Content review.
CRM-002	Must	The page shall provide exactly three primary starting actions.	DOM count and UX review.
CRM-003	Must	The page shall show catalog, scored fixture, scanner, and evidence status without	Snapshot and truth-copy test.

ID	Priority	Requirement	Verification
		overclaiming.	
CRM-004	Must	The Threat Constellation shall highlight relationships among entry surface, boundary, capability, control, evidence, and decision.	Graph selection test.
CRM-005	Must	The graph shall provide pan, zoom, search, filters, reset, keyboard focus, and a linear text alternative.	Interaction and accessibility tests.

5.4 Threat Workbench

ID	Priority	Requirement	Verification
THR-001	Must	The user shall be able to search scenarios by name, family, surface, status, and defense question.	Filter matrix test.
THR-002	Must	Each scenario shall expose name, beginner summary, family, surface, safe fixture, boundary, expected decision, and claim limit.	Schema and render test.
THR-003	Must	Selecting a scenario shall update the diagram, evidence drawer, expected outcome, and run readiness.	State synchronization test.
THR-004	Must	A rehearsal shall advance only authored local steps and shall not execute or contact an external system.	Static scan and runtime flags.
THR-005	Must	The result shall include decision, reason, evidence, boundary, execution status, target status, and next defensive action.	Receipt contract test.
THR-006	Must	The user shall be able to replay, compare, add to playbook, or return to the catalog.	Action test.
THR-007	Must	Technical records shall remain collapsed by default and contain only safe metadata or pseudocode.	DOM and content scan.

5.5 Multi-threat playbook composer

ID	Priority	Requirement	Verification
PBK-001	Must	The composer shall add, remove, reorder, duplicate, and clear scenario steps.	Composer interaction test.

ID	Priority	Requirement	Verification
PBK-002	Must	The current release shall enforce the documented four-case maximum unless the limit is intentionally revised.	Boundary test.
PBK-003	Must	The composer shall identify duplicate or incompatible adjacent steps.	Compatibility fixture test.
PBK-004	Must	The composer shall generate synchronized plain-English, safe pseudocode, and evidence-plan outputs.	Generated output test.
PBK-005	Must	Generated output shall state syntheticOnly, shadow-only, not-run, externalContacted false, and redacted evidence.	Output contract assertion.
PBK-006	Must	Copy and download actions shall provide visible and announced confirmation.	Clipboard mock and live-region test.

5.6 OS Boundary Lab

ID	Priority	Requirement	Verification
OSB-001	Must	The lab shall present process, file, permission, child-process, and network-request categories as non-executing adapters.	Adapter catalog test.
OSB-002	Must	Every adapter result shall keep processStarted, fileChanged, networkCalled, externalContacted, and executed false.	Unit test.
OSB-003	Must	Offline traffic replay shall use authored metadata with no raw packets, addresses, or live capture.	Fixture and network scan.
OSB-004	Must	Containment controls and kill switch shall change only in-memory state and emit a redacted ledger event.	State and ledger test.
OSB-005	Must	The privacy inspector shall state that redaction does not spoof an IP or provide anonymity.	Content assertion.
OSB-006	Must	Reset shall cancel pending replay timers before clearing state.	Race regression test.

5.7 Coverage Atlas

ID	Priority	Requirement	Verification
COV-001	Must	The Coverage Atlas shall expose views by family, surface, boundary, control, and evidence quality.	View switch test.
COV-002	Must	Every status shall have visible text and a definition beside the legend.	Legend audit.
COV-003	Must	Selecting a scenario or control shall highlight all mapped relationships and open an explanation.	Selection test.
COV-004	Must	Coverage gaps, shadow-only work, heuristic review, and not-tested states shall not use the same success treatment as enforced controls.	Visual state audit.
COV-005	Must	Beginner and technical modes shall preserve the same underlying status and evidence.	Mode parity test.

5.8 Guided Tour

ID	Priority	Requirement	Verification
GDE-001	Must	The tour shall cover PenTel setup, unprotected path, rewind, protected path, evidence receipt, and defense map.	Tour step test.
GDE-002	Must	The Benji seven-stage story shall preserve all seven authored stages and safety boundaries.	Content parity test.
GDE-003	Must	Users shall be able to go back, continue, skip animation, and resume without losing selected state.	Navigation state test.
GDE-004	Must	The tour shall finish with the exact defense and evidence highlighted.	Cross-page state test.

5.9 Guide and documentation

ID	Priority	Requirement	Verification
DOC-001	Must	The lab shall include an authenticated Guide + SRS page.	Route and authentication test.
DOC-002	Must	The page shall provide a searchable table of contents	Search and content test.

ID	Priority	Requirement	Verification
		and current-versus-planned labels.	
DOC-003	Must	The page shall link to the branded user guide PDF, SRS PDF, and editable SRS DOCX.	Authenticated download test.
DOC-004	Must	Definitions shall be available by hover, focus, tap, and inline text.	Multi-input help test.
DOC-005	Must	The documentation page shall never expose the owner token or private repository paths.	Content scan.

5.10 Evidence and action receipts

ID	Priority	Requirement	Verification
EVD-001	Must	Every consequential control shall produce a visible action receipt.	Control inventory test.
EVD-002	Must	Receipts shall identify action, result, local state changed, evidence, and what did not occur.	Receipt schema test.
EVD-003	Must	Evidence shall be redacted by default and shall not reproduce hostile instruction content.	Leakage regression test.
EVD-004	Must	Receipt and ledger records shall preserve causal order and a stable run identifier.	Ordering test.

6. Data and state model

Entity	Required fields	Persistence
Scenario	id, name, family, surface, safeFixture, boundary, status, summary, defense mapping	Versioned source fixture.
Run	runId, scenarioId, mode, currentStep, decision, timestamps	Session memory only in current release.
Evidence event	eventId, runId, type, redacted detail, source, decision linkage	Session ledger and safe export.
Action receipt	action, outcome, state change, evidence, exclusions, time	Session memory and optional download.
Playbook	ordered scenario IDs, compatibility notes, output modes, generated manifest	Session memory; explicit local download only.
Coverage mapping	scenarioId, surface, defense question, control, implementation state, evidence quality	Versioned source fixture.
Documentation item	section, current/planned state, plain	Approved static asset.

Entity	Required fields	Persistence
	explanation, technical reference	

6.1 Run state machine

1. Idle
2. Scenario selected
3. Ready
4. Rehearsing
5. Decision emitted
6. Receipt available
7. Replayed or reset

Invariant: Reset must cancel every pending timer and leave the ledger empty. No delayed callback may repopulate a cleared run.

7. External interfaces

Interface	Contract	Security behavior
GET /health	Returns minimal service health JSON.	Public, no secret or repository detail.
GET /robots.txt	Disallow all crawling.	Public.
GET /gate.html and /gate.mjs	Render owner access exchange.	Public but no token embedded in source.
POST /session	Accept access value in JSON body and issue session cookie.	HTTPS, constant-time comparison, no-store.
GET authenticated assets	Serve approved HTML, JS, CSS, and documentation downloads.	401 without cookie; CSP and noindex headers.
Private runner and CanaryNorth pairing	Local development and test interface only.	Never exposed by the presentation server.

8. Security and privacy requirements

ID	Priority	Requirement	Verification
SEC-001	Must	The server shall use constant-time token and cookie comparisons.	Code review and unit test.
SEC-002	Must	The application shall set CSP, no-store, noindex, X-Frame-Options DENY, and no-referrer headers.	Header smoke test.
SEC-003	Must	The served asset resolver shall prevent traversal outside the approved lab-ui root.	Traversal negative tests.
SEC-004	Must	No page shall store the owner token in localStorage, sessionStorage, IndexedDB, logs, or downloadable	Static and browser storage scan.

ID	Priority	Requirement	Verification
		artifacts.	
SEC-005	Must	No lab module shall use child_process, shell, file mutation, raw sockets, browser automation, credential stores, or external endpoints.	Static forbidden-API scan.
SEC-006	Must	Every scenario and receipt shall remain redacted, target-free, and free of executable payloads.	Fixture and output scan.
ID	Priority	Requirement	Verification
PRV-001	Must	The system shall distinguish redaction from identity or network anonymity.	Content assertion.
PRV-002	Must	The lab shall collect no analytics or third-party telemetry in the current release.	Network and source scan.
PRV-003	Must	Downloads shall contain no secrets, owner identifiers, raw hostile content, or private absolute paths.	Artifact scan.

9. Nonfunctional requirements

ID	Priority	Requirement	Verification
PERF-001	Must	Authenticated static pages should reach interactive state within 2.5 seconds on a typical broadband connection and modern phone.	Lighthouse or browser timing sample.
PERF-002	Must	Search and filter feedback shall appear within 100 milliseconds for the current 72-case catalog.	Performance test.
PERF-003	Must	Graph selection and panel transitions shall maintain responsive interaction without long main-thread blocks.	Browser performance profile.
ID	Priority	Requirement	Verification
REL-001	Must	A failed copy, download, or unsupported browser action shall show a recoverable error.	Failure-path test.
REL-002	Must	A page refresh shall preserve only non-sensitive selected scenario and mode state when	State persistence test.

ID	Priority	Requirement	Verification
		implemented.	
REL-003	Must	No failed documentation asset shall break primary lab navigation.	Missing-download test.
ID	Priority	Requirement	Verification
MNT-001	Must	Design tokens, motion durations, breakpoints, and component states shall be centralized.	Source audit.
MNT-002	Must	Legacy visual overrides shall be removed instead of extended with another terminal theme layer.	CSS cascade audit.
MNT-003	Must	Scenario data shall remain separate from rendering logic.	Module boundary review.
ID	Priority	Requirement	Verification
TRU-001	Must	The interface shall label current, planned, heuristic, not-run, and simulated states accurately.	Truth-copy matrix test.
TRU-002	Must	The scored fixture result shall not be presented as proof of universal detection.	Content assertion.
TRU-003	Must	Malware, steganography, and ML labels shall reflect actual connected capability.	Capability status test.

10. Accessibility and responsive requirements

ID	Priority	Requirement	Verification
A11Y-001	Must	All interactive elements shall be keyboard reachable and show visible focus.	Keyboard-only test.
A11Y-002	Must	Status shall not be communicated by color alone.	Visual and semantic audit.
A11Y-003	Must	Graph relationships shall have an equivalent ordered text representation.	Screen-reader review.
A11Y-004	Must	Dynamic results shall use appropriate live regions without excessive announcements.	Assistive-technology test.
A11Y-005	Must	Tooltips shall work on hover, focus, tap, and through accessible descriptions.	Input-mode matrix test.
A11Y-006	Must	Reduced-motion preference shall remove ambient drift	Media-query test.

ID	Priority	Requirement	Verification
		and shorten nonessential transitions.	
A11Y-007	Must	The interface shall have no page-level horizontal overflow at 390 pixels.	Viewport assertion.
A11Y-008	Must	Tables shall become labeled cards or controlled internal scroll regions on small screens.	Responsive browser QA.

11. Observability and evidence

- Every run has a local run ID and ordered event sequence.
- Evidence explains the decision without preserving hostile content.
- The human can identify the originating scenario, trust boundary, control, and result.
- Operational logs must not include the owner token, cookie value, raw fixture content, or private absolute paths.
- Health checks expose only service availability and the synthetic-only identity.

12. Test and acceptance strategy

Layer	Minimum evidence	Release gate
Unit	Scenario contract, server gate, receipts, state transitions, reset race, generated outputs.	All tests pass.
Integration	Five pages plus Guide + SRS, authenticated downloads, shared navigation, cross-page state.	All routes and flows pass.
Security	401 without cookie, 404 private files, header policy, traversal, forbidden APIs, secret scan.	Zero critical findings.
Accessibility	Keyboard, focus, live regions, graph fallback, contrast, reduced motion, 390px layout.	No blocking defect.
Visual	Desktop and mobile screenshots for all primary states.	No clipping, overflow, dead controls, or legacy-theme leakage.
Production	Railway deployment SUCCESS plus exact route and browser checks.	Terminal and browser evidence agree.

12.1 Definition of done

- A first-time user can complete the guided rehearsal and accurately describe what happened.
- The Threat Constellation is useful, interactive, keyboard-accessible, and has a linear alternative.
- Protected versus unprotected comparison produces synchronized evidence and explanations.
- Every visible control has a result or an explanation of why it cannot complete.
- All current repository tests and all new UI tests pass.
- The owner gate still strips the fragment, authenticated downloads work, and private files remain inaccessible.
- Browser QA passes at all required widths and the deployed release is verified separately from the build status.

13. Deployment and operations

8. Run the full private test suite and syntax checks.
9. Run secret, forbidden-API, external-endpoint, and diff checks.
10. Build and render documentation artifacts, then inspect every page.
11. Deploy to the dedicated Railway service with the owner token already configured.
12. Wait for terminal deployment status SUCCESS.
13. Verify public health and robots routes, unauthenticated 401 behavior, authenticated pages and downloads, private-file 404 behavior, and browser-visible flows.
14. Rotate the owner token if the access email or link is exposed.

14. Traceability matrix

Product goal	Requirement groups	Primary verification
Owner-only lab	AUTH, SEC	Server tests, route smoke, browser gate QA
Understand one threat	CRM, THR, GDE	Guided rehearsal and receipt tests
Compose threat sequences	PBK	Composer interaction and output contract tests
Explain OS boundary	OSB	Adapter flag and forbidden-API tests
Understand defense status	COV, TRU	Legend, mode parity, truth-copy tests
Accessible and mobile	NAV, A11Y, PERF	Keyboard, screen-reader, responsive, timing tests
Self-documenting product	DOC, EVD	Search, download, glossary, receipt tests

15. Risks, limitations, and release gates

Risk	Impact	Mitigation / gate
UI polish outruns product truth	Misleading security claims.	Truth-copy matrix and capability-state tests.
Graph becomes decoration	Complexity without comprehension.	Require text fallback and task-based usability review.
Legacy CSS remains stacked	Fragile, inconsistent interface.	Delete conflicting layers and audit computed styles.
Owner link is shared	Unauthorized access to private presentation.	Rotate token; never store it in docs or source.
Synthetic score is overgeneralized	False confidence.	Keep scoped scorecard language next to metrics.
Documentation drifts	Guide no longer matches product.	Version docs with the release and test required links.

Appendix A. Status vocabulary

State	Meaning	What it does not mean
Blocked	The catalog outcome says a harmless	Not proof that the public product has a

State	Meaning	What it does not mean
	local fixture was stopped by a deterministic harness rule.	paired defense for every blocked card.
Enforced	A tested CanaryNorth policy control is connected to the named paired path and makes the decision.	Not enterprise deployment, universal coverage, or independent validation.
Shadow-only	A scenario is catalogued and produces reviewable synthetic evidence.	No live prevention is claimed.
Heuristic review	Bounded signals suggest manual review.	Not validated steganography detection.
Not run	No approved scanner or action executed.	Not clean or safe.
Allowed control	A bounded clean fixture reaches the fake target after allow.	Not an external target or production approval.

Appendix B. Current scenario inventory

Scenario	Family	State
The Helpful PDF	Indirect prompt injection	blocked
Ghost Authority	Authority confusion	blocked
Memory Drift	Memory poisoning	blocked
Schema Mirage	Tool metadata	blocked
Graph Twin	Expected vs observed graph	shadow-only
Consensus Illusion	Multi-agent provenance	shadow-only
Temporal Wormhole	Stale approval and memory	shadow-only
Canary Geometry	Canary resource traversal	shadow-only
Policy Gravity	Risk-weighted authorization	shadow-only
Picture Frame	File-type and execution boundary	shadow-only
Recruiter Calendar Mirage	Calendar and external-contact authorization	shadow-only
Trajectory Fork	Trajectory integrity	shadow-only
Passport Smuggle	Capability provenance	shadow-only
Clockwork Approval	Approval freshness	shadow-only
Browser Same-Origin Mirage	Browser boundary	shadow-only
Token Furnace	Secret-shaped metadata	shadow-only
Router Roulette	Route selection integrity	shadow-only
Receipt Dissonance	Receipt and action consistency	shadow-only
Quiet Permission	Composed permission scope	shadow-only
Scheduler Drift	Time and freshness consistency	shadow-only
Context Fork Bomb	Context lineage and fan-out	shadow-only
Evidence Shadow	Evidence provenance and visibility	shadow-only
Human Intent Drift	Human intent continuity	shadow-only
Model Identity Mirage	Runtime identity continuity	shadow-only
Shadow Invoice	Exact-artifact binding	shadow-only

PENTEL LAB / SYSTEM REQUIREMENTS SPECIFICATION

Scenario	Family	State
Semantic Doppelganger	Cross-format intent consistency	shadow-only
Dead-Drop Retrieval	Revocation and retrieval lineage	shadow-only
Canary Mimic	Decoy-independent coverage	shadow-only
Relay Blindspot	Handoff provenance continuity	shadow-only
Causal Cut	Causal evidence continuity	shadow-only
Trust Debt	Unresolved-risk accumulation	shadow-only
Recovery Mirage	Recovery claim integrity	shadow-only
Delegation Expiry	Handoff freshness	shadow-only
Platform Passport Drift	Cross-platform skill reuse	shadow-only
Execution Boundary Request	Execution boundary	shadow-only
Training Corpus Taint	Training-data provenance	shadow-only
Retry Storm Budget	Resource amplification	shadow-only
Destination Class Mirage	Server-side request boundary	shadow-only
Unregistered Tool Inventory	Tool inventory governance	shadow-only
Model Exposure Boundary	Model data exposure	shadow-only
Hidden Ink	Hidden-content review	blocked
Tool Shadow	Tool identity	blocked
Memory Canary	Memory poisoning	blocked
Tenant-Hop Replay	Tenant isolation	blocked
Benji's Long Game	Stateful multi-step risk	blocked
Echo Ladder	Provenance drift	shadow-only
Glass Elevator	Gradual privilege escalation	shadow-only
Mirror Badge	Tool identity confusion	shadow-only
Borrowed Room	Context and tenant confusion	shadow-only
Silver Lid	MacBook device authority	shadow-only
Inbox Mirage	Email trust	shadow-only
Achievement Bait	Xbox-style social engineering	shadow-only
Save Point	Video game mod metadata	shadow-only
Beacon Name	Wi-Fi name injection	shadow-only
Portal Peel	QR destination confusion	shadow-only
Double Exposure	Identity binding	shadow-only
Prompt Storm	MFA resilience	shadow-only
Recovery Trap	MFA resilience	shadow-only
Borrowed Session	MFA resilience	shadow-only
Old Challenge	MFA resilience	shadow-only
Phone Number Risk	MFA resilience	shadow-only
Scope Creep App	MFA resilience	shadow-only
Unfamiliar Device	MFA resilience	shadow-only
Receipt Time Machine	Approval freshness	shadow-only
Empty Handshake	Tool outcome integrity	shadow-only

Scenario	Family	State
Quarantine Escape	Quarantine boundary	shadow-only
The Polite Insider	Cumulative least privilege	shadow-only
Borrowed Badge	Identity and privilege abuse	blocked
Scope Escape	Resource authorization	blocked
Expired Keycard	Capability lifecycle	blocked
Nonce Impostor	Replay and freshness	blocked
Clean synthetic request	Control case	allowed

Appendix C. Requirement glossary

Term	Definition
Capability	A narrowly scoped permission to perform a specific action on a specific resource.
Evidence	The safe supporting record used to explain why a decision was made.
Provenance	Where a message, file, tool result, or decision came from and how that lineage was preserved.
Trust boundary	The point where information or authority moves between systems, people, agents, tenants, or privilege levels.
Blast radius	The systems, people, data, or actions that could be affected if a decision were wrong.
Action receipt	A human-readable record of the requested action, decision, evidence, and explicit non-actions.
Synthetic fixture	Authored harmless metadata used to test a control without a real target or payload.